UNIVERSIDAD PRIVADA DE TACNA
FACULTAD DE INGENIERÍA
ESCUELA DE INGENIERÍA DE SISTEMAS

Guia Practica de Laboratorio

Laboratorio 02
“Auditoría Móvil”

Que se presenta para el curso:
“Auditoría de sistemas”

Integrante(s):
Flores Melendez, Andree Sebastián (2017057494)

Docente:
Dr. Oscar Juan Jimenez Flores

TACNA – PERÚ
2026

Índice General

Introducción 3
1. Información sobre el evento práctico 4
1.1. Título del evento práctico 4
Laboratorio 01. Auditoria de vulnerabilidades en imágenes Docker 4
1.2. Objetivos 4
1.3. Tiempo de duración (horas) 4
1.4. Resultados de Aprendizaje (RA) 4
1.5. Recursos (Equipos, materiales, programas y otros) 4
2. Procedimiento o Metodología 5
3. Conclusiones 14
4. Referencias 14

Introducción

La auditoría de seguridad en Tecnologías de la Información y Comunicación (TIC) es un proceso sistemático y estructurado que evalúa la eficacia y la integridad de los controles de seguridad implementados en una organización. Su objetivo principal es identificar vulnerabilidades, asegurar el cumplimiento de políticas y normas, y verificar que los sistemas de TIC protejan adecuadamente la confidencialidad, integridad y disponibilidad de la información.

Durante una auditoría de seguridad en TIC, se examinan diversos aspectos, como la configuración de hardware y software, los controles de acceso, las políticas de seguridad, los procedimientos de respaldo y recuperación, y la gestión de incidentes. Además, se evalúan las prácticas de gestión de riesgos y el cumplimiento de normativas y estándares relevantes.

El objetivo de este laboratorio es realizar una auditoría de seguridad, analizar los posibles riesgos asociados y proponer controles.

Guía de Laboratorio N.º 02 "Auditoria de seguridad y hallazgos"

1. Información sobre el evento práctico

1.1. Título del evento práctico

Laboratorio 02. Auditoría Móvil

1.2. Objetivos

- Identificar los elementos que participan en la Auditoría de seguridad.
- Analizar los posibles riesgos asociados.
- Proponer controles efectivos para minimizar el riesgo asociado.

1.3. Tiempo de duración (horas)

06 horas académicas

1.4. Resultados de Aprendizaje (RA)

[AG-I02] Ética
[AG-I04] Comunicación
[AG-I07] Conocimientos de Ingeniería
[AG-I08] Análisis de Problemas
[AG-I09] Diseño y Desarrollo de Soluciones
[AG-I11] Uso de Herramientas

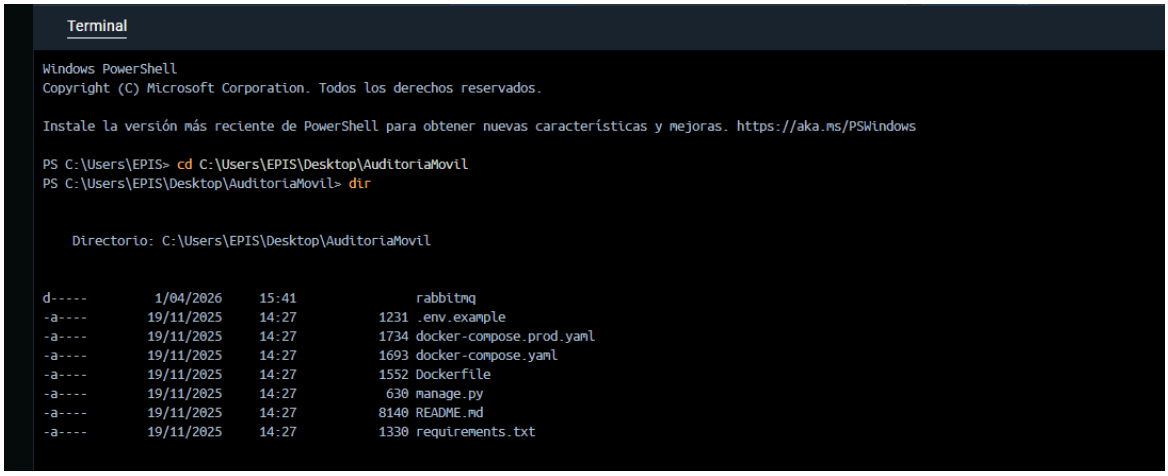
1.5. Recursos (Equipos, materiales, programas y otros)

- Computador con S.O.
- Descargar e instalar repositorio GIT https://github.com/OscarJimenezFlores/CursoAuditoria/tree/main/AuditoriaMovil

2. Procedimiento o Metodología

Instalación

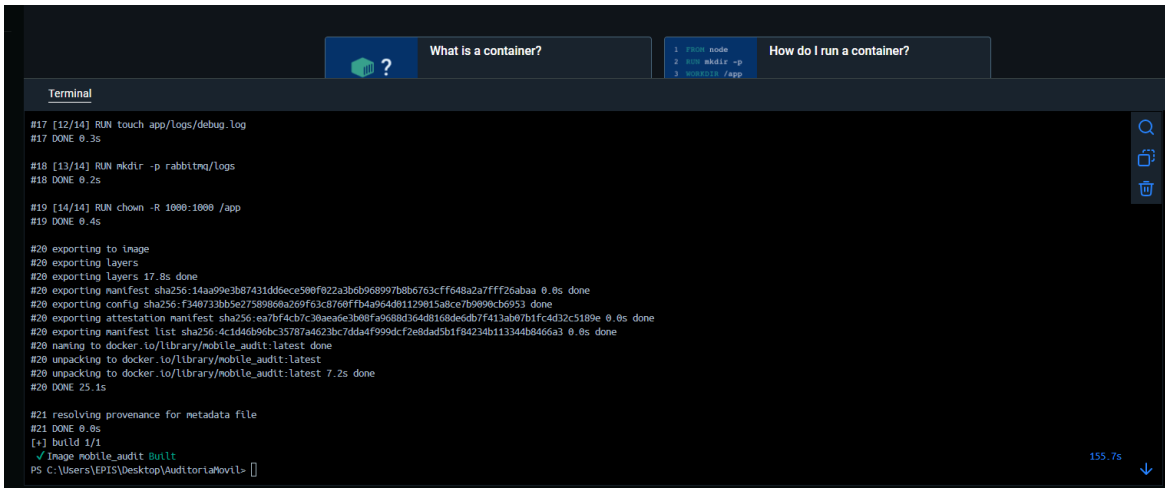
Usando Docker-compose: El archivo docker-compose.yml proporcionado permite ejecutar la aplicación localmente en desarrollo.



```
Terminal

Windows PowerShell
Copyright (C) Microsoft Corporation. Todos los derechos reservados.

Instale la versión más reciente de PowerShell para obtener nuevas características y mejoras. https://aka.ms/PSWindows

PS C:\Users\EPIS> cd C:\Users\EPIS\Desktop\AuditoriaMovil
PS C:\Users\EPIS\Desktop\AuditoriaMovil> dir


    Directorio: C:\Users\EPIS\Desktop\AuditoriaMovil


d-----        1/04/2026     15:41                rabbitmq
-a----       19/11/2025     14:27           1231 .env.example
-a----       19/11/2025     14:27           1734 docker-compose.prod.yaml
-a----       19/11/2025     14:27           1693 docker-compose.yaml
-a----       19/11/2025     14:27           1552 Dockerfile
-a----       19/11/2025     14:27            630 manage.py
-a----       19/11/2025     14:27           8140 README.md
-a----       19/11/2025     14:27           1330 requirements.txt
```

1. **Construir la imagen**

Para construir la imagen local y si hay cambios en el Dockerfile de la aplicación, puedes construir la imagen con: **docker-compose build**

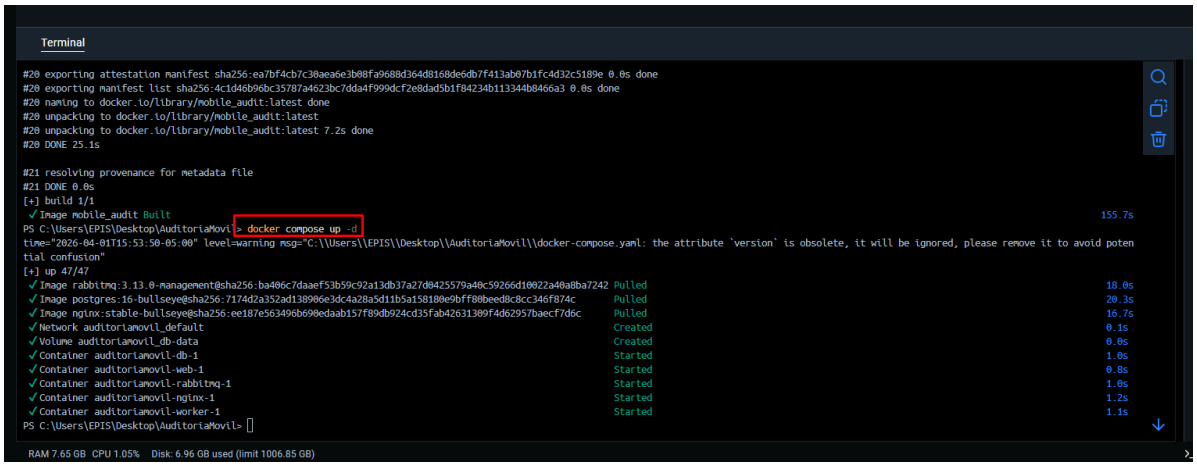


```
What is a container?
How do I run a container?
Terminal

#17 [12/14] RUN touch app/logs/debug.log
#17 DONE 0.3s

#18 [13/14] RUN mkdir -p rabbitmq/logs
#18 DONE 0.2s

#19 [14/14] RUN chown -R 1000:1000 /app
#19 DONE 0.4s

#20 exporting to image
#20 exporting layers
#20 exporting layers 17.8s done
#20 exporting manifest sha256:14aa99e3b87431dd6ece500f022a3b6b968997b8b6763cff648a2a7fff26abaa 0.0s done
#20 exporting config sha256:f340733bb5e27589860a269f63c8760ffb4a964d0129015a8ce7b9090cb6953 done
#20 exporting attestation manifest sha256:ea7bf4cb7c30aea6e3b08fa9688d364d8168de6db7f413ab07b1fc4d32c5189e 0.0s done
#20 exporting manifest list sha256:4c1d46b96bc35787a4623bc7dda4f999dcf2e8dad5b1f84234b113344b8466a3 0.0s done
#20 naming to docker.io/library/mobile_audit:latest done
#20 unpacking to docker.io/library/mobile_audit:latest
#20 unpacking to docker.io/library/mobile_audit:latest 7.2s done
#20 DONE 25.1s

#21 resolving provenance for metadata file
#21 DONE 0.0s
[+] build 1/1
 ✓ Image mobile_audit Built
PS C:\Users\EPIS\Desktop\AuditoriaMovil>
155.7s
```

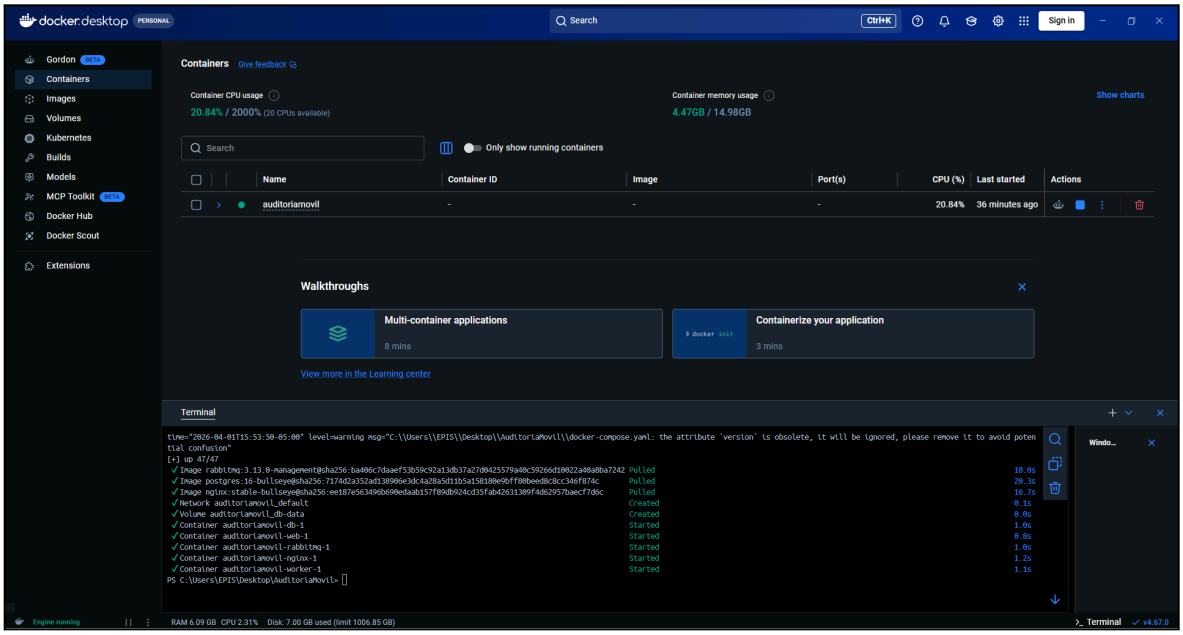
EXPLICACIÓN DE LA CAPTURA: Se ejecuta docker compose build, donde Docker construye la imagen del proyecto descargando las dependencias necesarias. Aparece una advertencia que no afecta el proceso. Al finalizar sin errores, se confirma que la imagen mobile_audit se creó correctamente y ya está lista para usarse.

2. Levantar la aplicación

Luego, para iniciar el contenedor, ejecuta: **docker-compose up,** Opcional: ejecuta en modo separado (sin ver los logs) **docker-compose up -d**



EXPLICACIÓN DE LA CAPTURA: Se ejecuta docker compose up -d, lo que inicia los contenedores en segundo plano. Docker descarga las imágenes necesarias como PostgreSQL, RabbitMQ y Nginx, crea la red y los volúmenes, y luego levanta todos los servicios del proyecto.

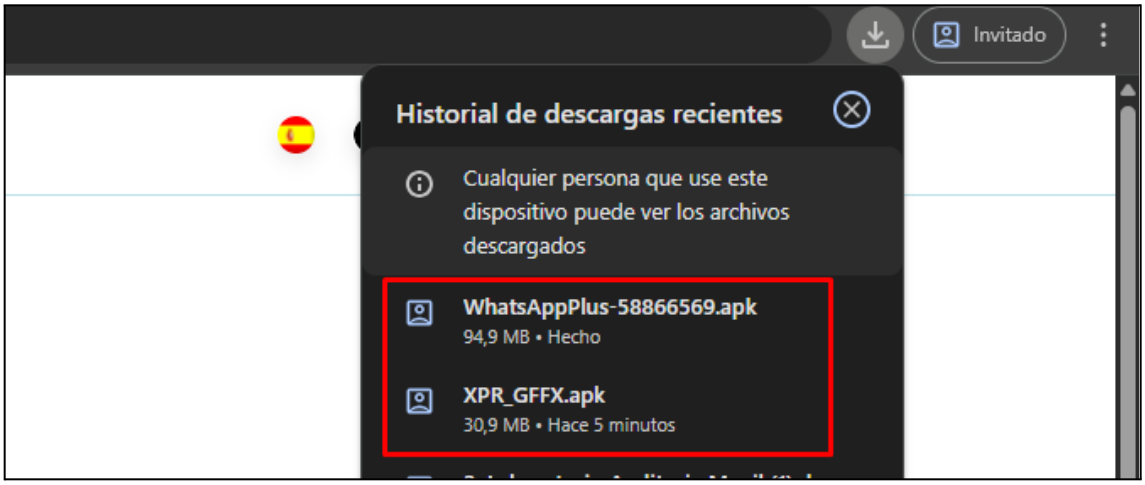


3. Abrir en navegador

Una vez que la aplicación esté en marcha, puedes probarla navegando a: http://localhost:8888/ para acceder al tablero de control.

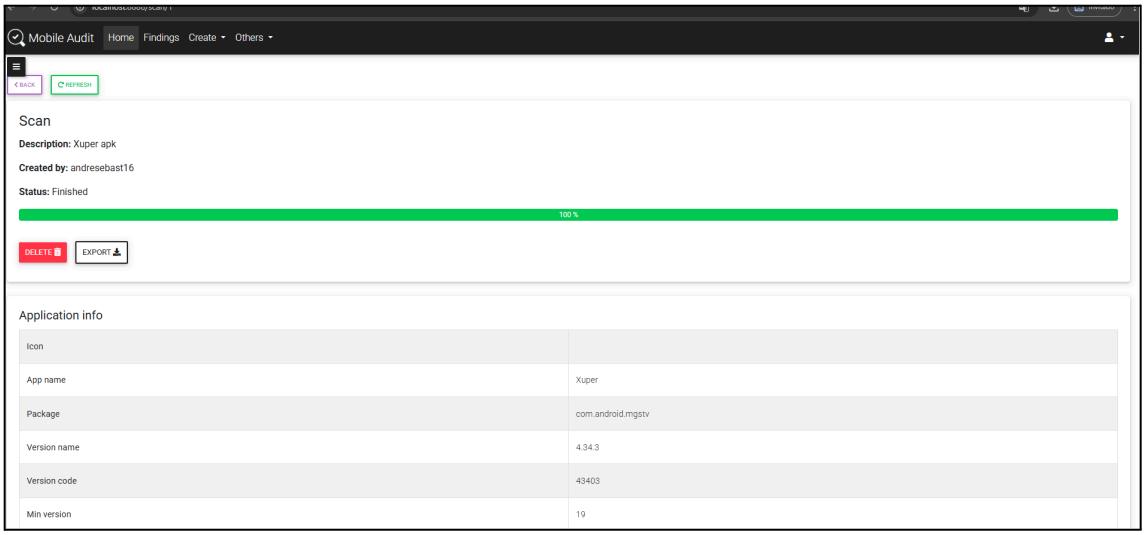
EXPLICACIÓN DE LA CAPTURA: Inicialmente el sistema está funcionando, pero aún no se ha cargado nada.

Descargamos dos apk para probar, en mi caso usare Xuper y Whatsapp Plus, estas apk posiblemente tengan malware asi que seran perfectas para analizar

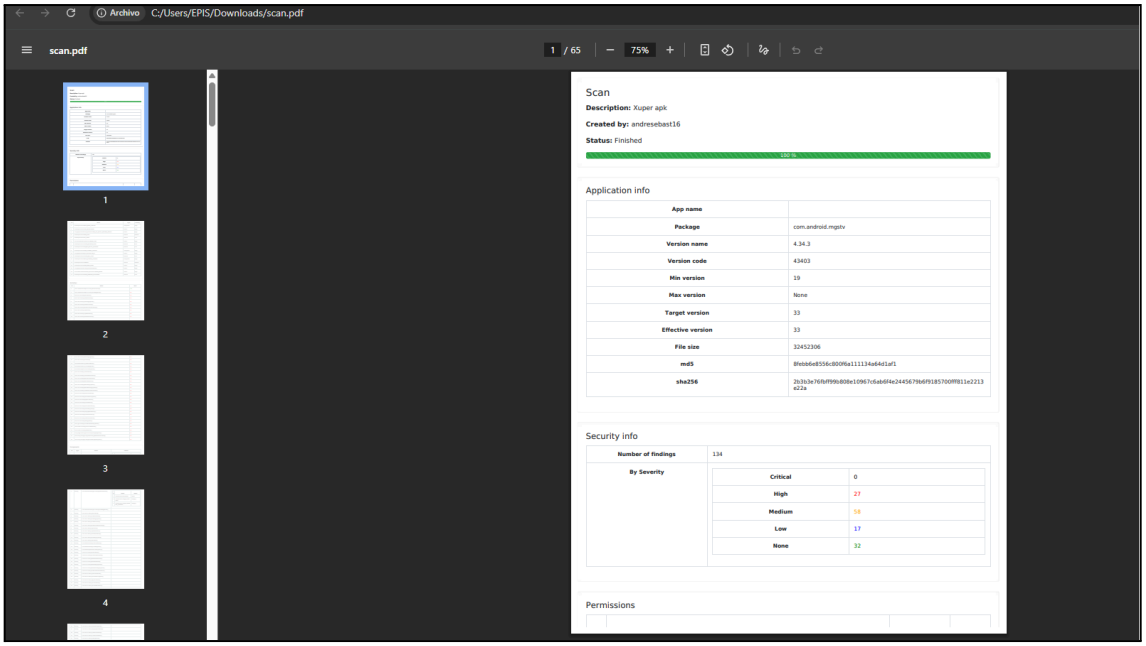


4. Analizando APKs

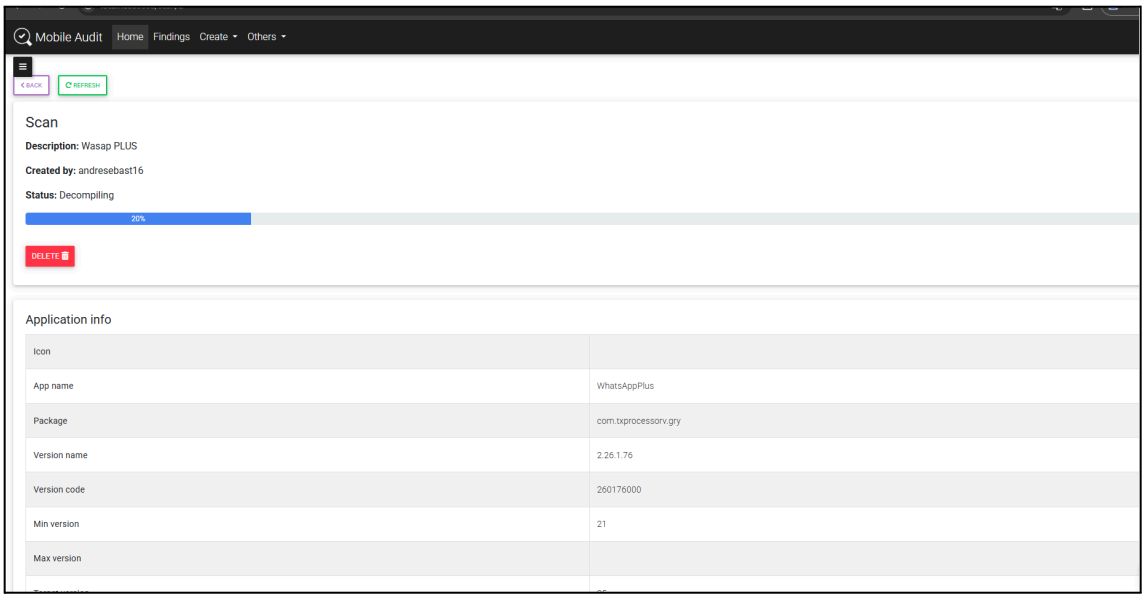
Creamos una cuenta y después creamos para poder abrir el apk y analizar, nos pedirá nombre descripción y seleccionar el apk



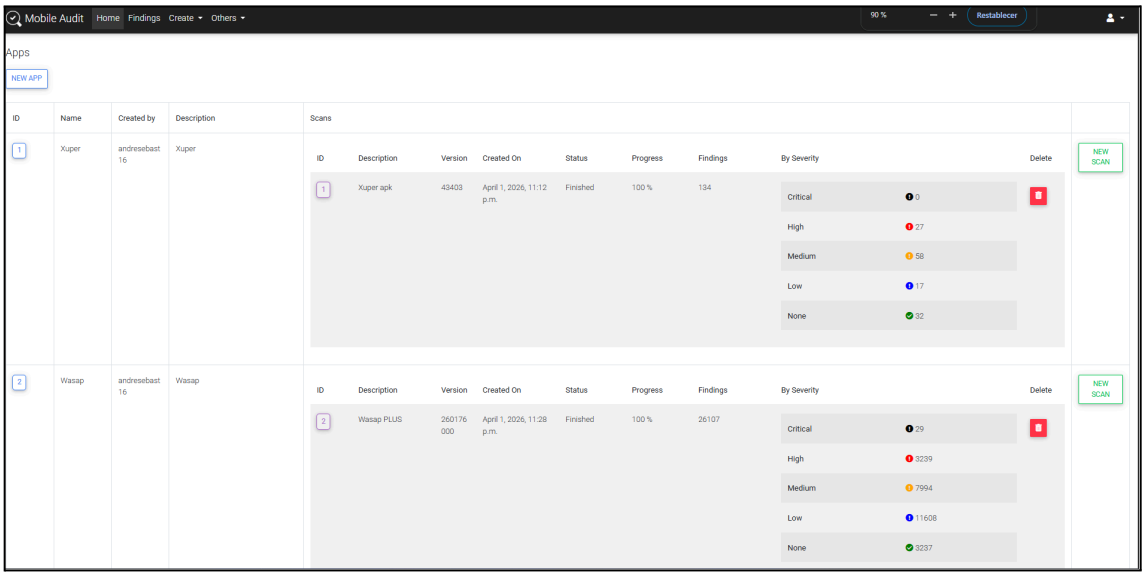
EXPLICACIÓN DE LA CAPTURA: Se observa que la aplicación ya está funcionando correctamente en el navegador, donde se realizó un escaneo de una APK. El sistema muestra que el análisis está en proceso , lo que indica que la herramienta está revisando posibles vulnerabilidades.



EXPLICACIÓN DE LA CAPTURA: Una vez le demos al boton de “Export” se nos generará un .pdf donde podremos ver todo el scan detalladamente de la apk



EXPLICACIÓN DE LA CAPTURA: Repetimos los mismos pasos anteriores pero esta vez analizaremos el otro apk (whatsapp Plus) e igualmente podremos exportar un archivo .pdf con el scan completo



EXPLICACIÓN DE LA CAPTURA: Una vez termine lso procesos de ambos apks podemos regresar a Home y veremos las apps que fueron escaneadas con sus resultados de escaneos

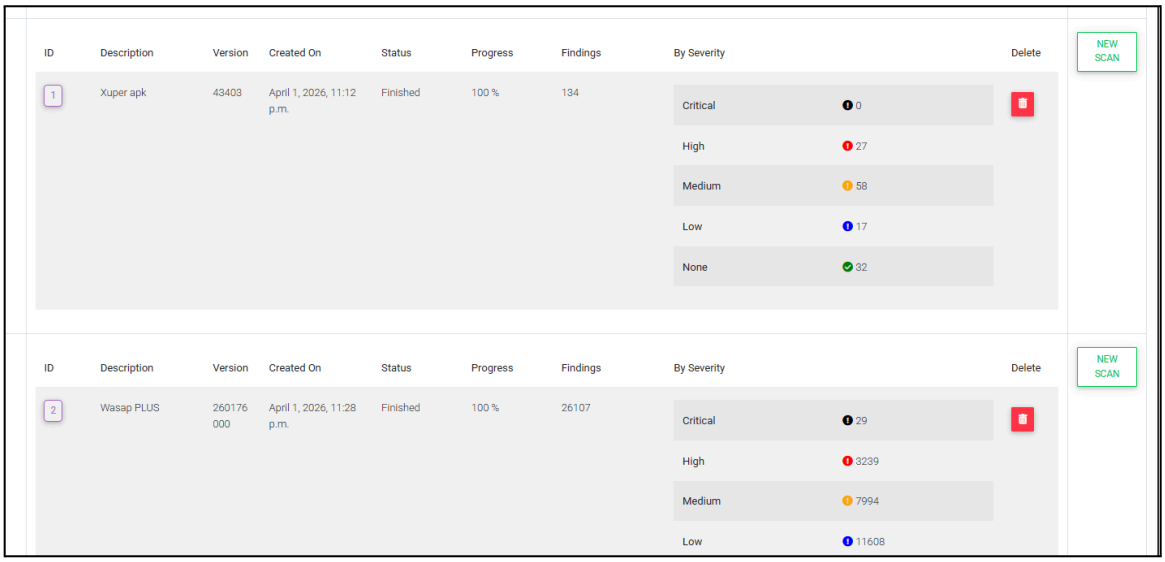
5. Resultados

Resultado 1: Implementación exitosa del entorno

Se logró implementar correctamente el entorno de auditoría móvil mediante Docker Compose, permitiendo la ejecución de múltiples servicios como base de datos, servidor web y herramientas de análisis de forma integrada. La aplicación se desplegó sin errores y fue accesible desde el navegador en http://localhost:8888/.

Resultado 2: Carga y análisis de aplicaciones APK

Se realizó la carga y análisis de dos aplicaciones APK (Xuper y WhatsApp Plus), comprobando que la plataforma permite gestionar múltiples aplicaciones y ejecutar procesos de escaneo de manera eficiente desde la interfaz web.

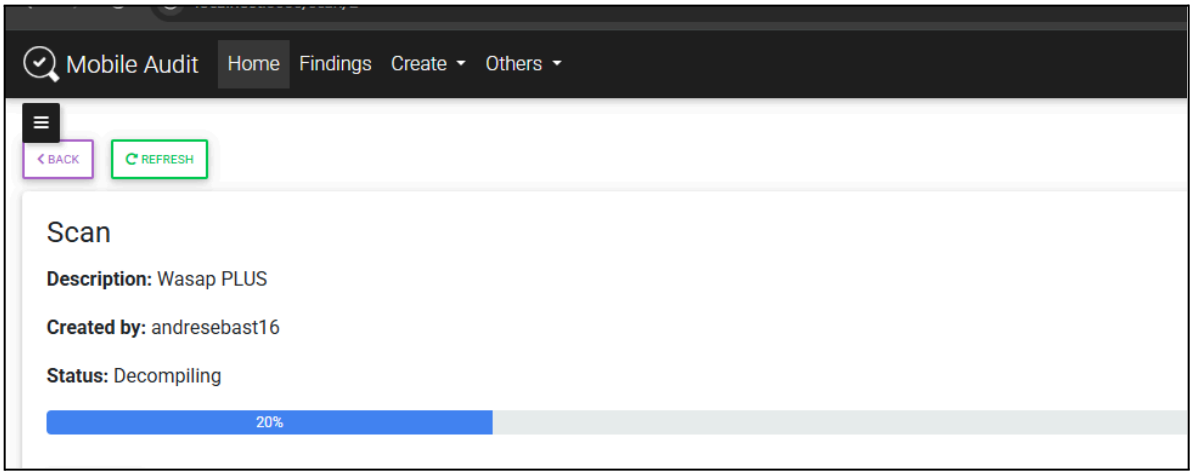


ID	Description	Version	Created On	Status	Progress	Findings	By Severity		Delete	
1	Xuper apk	43403	April 1, 2026, 11:12 p.m.	Finished	100 %	134	Critical	0		NEW SCAN
							High	27		
							Medium	58		
							Low	17		
							None	32		

ID	Description	Version	Created On	Status	Progress	Findings	By Severity		Delete	
2	Wasap PLUS	260176 000	April 1, 2026, 11:28 p.m.	Finished	100 %	26107	Critical	29		NEW SCAN
							High	3239		
							Medium	7994		
							Low	11608		

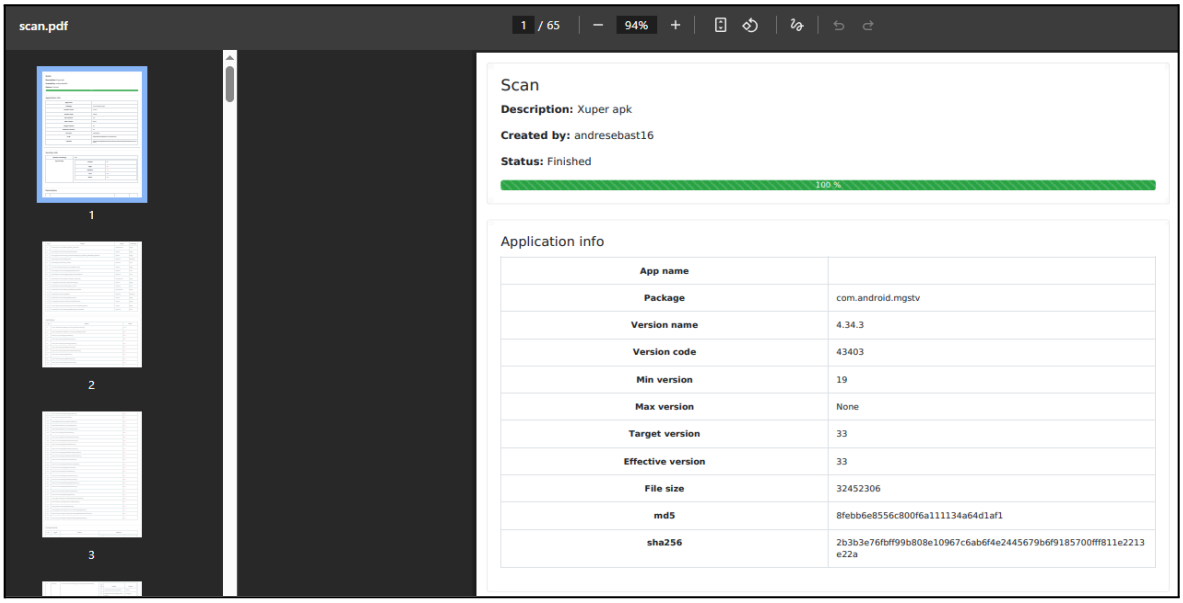
Resultado 3: Proceso de escaneo y detección

Durante el análisis, el sistema ejecutó correctamente los procesos de evaluación de seguridad, mostrando el estado de los escaneos en tiempo real y permitiendo identificar posibles riesgos y vulnerabilidades en las aplicaciones analizadas.



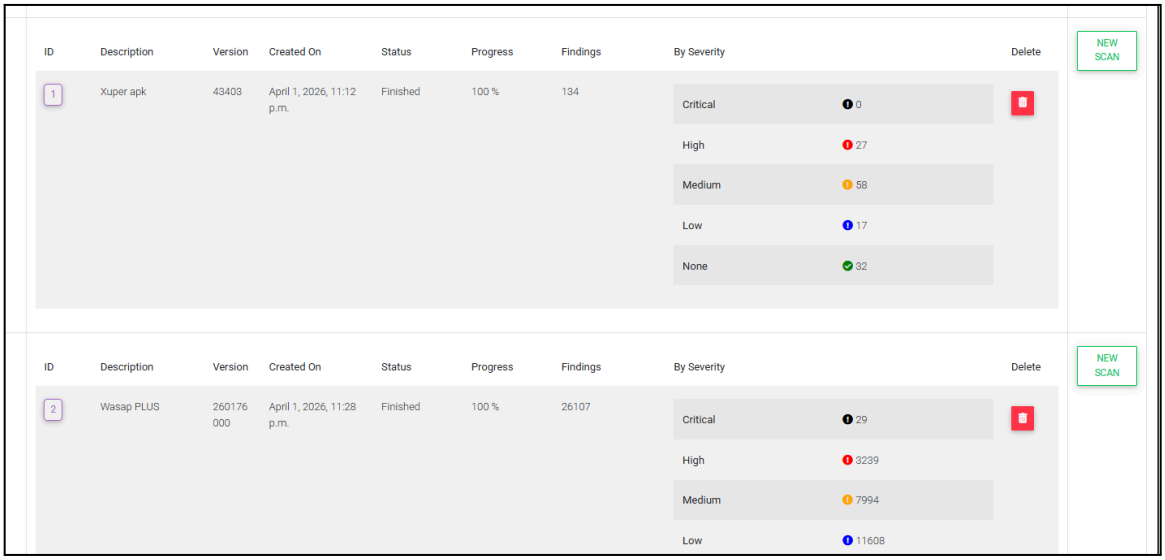
Resultado 4: Generación de reportes

La herramienta permitió exportar los resultados del análisis en formato PDF, proporcionando informes detallados sobre cada APK, lo cual facilita la revisión y documentación de vulnerabilidades encontradas.



Resultado 5: Gestión centralizada de resultados

Finalmente, se verificó que el sistema almacena y muestra de forma organizada todas las aplicaciones analizadas junto con sus resultados, permitiendo una gestión centralizada y seguimiento de los escaneos realizados.



ID	Description	Version	Created On	Status	Progress	Findings	By Severity		Delete
1	Xuper apk	43403	April 1, 2026, 11:12 p.m.	Finished	100 %	134	Critical	0	
							High	27	
							Medium	58	
							Low	17	
							None	32	

NEW SCAN

ID	Description	Version	Created On	Status	Progress	Findings	By Severity		Delete
2	Wasap PLUS	260176 000	April 1, 2026, 11:28 p.m.	Finished	100 %	26107	Critical	29	
							High	3239	
							Medium	7994	
							Low	11608	

NEW SCAN

LINK DE REPOSITORIO

Aqui encontraremos el scan y los apk utilizados en este laboratorio

https://github.com/andresebast161616/AuditoriaMovil

3. Conclusiones

- El análisis de aplicaciones APK descargadas de fuentes no confiables permitió identificar múltiples riesgos de seguridad, como permisos excesivos, posible presencia de malware y comportamientos sospechosos, lo que evidencia la importancia de verificar la procedencia de las aplicaciones antes de instalarlas.

- El uso de herramientas de auditoría móvil facilitó la detección de vulnerabilidades y malas prácticas en las aplicaciones analizadas, demostrando que el análisis estático y dinámico es fundamental para evaluar la seguridad de aplicaciones móviles de manera efectiva.

- Se comprobó que muchas aplicaciones consideradas “peligrosas” pueden comprometer la privacidad del usuario, accediendo a datos sensibles como ubicación, contactos o almacenamiento, lo que resalta la necesidad de implementar controles de seguridad y concientización en los usuarios.

4. Referencias

- Calder, A., & Watkins, S. (2015). IT Governance: An International Guide to Data Security and ISO27001/ISO27002. Kogan Page.
- Orebaugh, A., Ramirez, D., Beale, J., & Wright, J. (2006). Wireshark & Ethereal Network Protocol Analyzer Toolkit. Syngress.
- Stallings, W., & Brown, L. (2018). Computer Security: Principles and Practice (4th ed.). Pearson.
- Weaver, A. C. (2013). Computer Security: A Hands-on Approach. CRC Press. AlphaCloud
- Del Peso, E., Del Peso, M., & Piattini, M. (2008). Auditoría de tecnologías y sistemas de información. Rama. ISBN 9788499646039.